

Renewing certification authorities

sysadmins.lv/documentation/nt5certsrvdocs/Renew.aspx

Vadims Podāns



Historical Content Alert

This is a historical content for **Windows 2000** product and is presented for informative purposes only. All content on this page is copyrighted and owned by Microsoft.

Why certification authorities need to be renewed

Every certificate issued by a certification authority (CA) has a validity period. The validity period is the range of time where the certificate can be accepted as an authoritative credential of the identity of the subject of the certificate. This is, of course, assuming the certificate is not revoked before the validity period ends and that the issuing CA is trusted.

Since a CA is really just another entity that has been issued a certificate--either issued by itself (in the case of a root CA) or issued by a parent (in the case of a subordinate CA)--every CA has a built-in "expiration date" as determined by the end of the validity period on its CA certificate. This is not meant to imply that the "lifetime" of a CA is equivalent to the validity period of its CA certificate, only that a CA can not issue certificates if it does not have a valid certificate of its own. The lifetime of a CA includes the validity periods of all its

CA certificates--past and present. With these considerations in mind, an organization with a public key infrastructure (PKI) has to plan for the "renewal" of every certificate issued to a CA in the certification hierarchy in order to maintain the existing trust relationships in the PKI and to extend the lifetimes of CAs.

The validity period of a CA and the validity period of the certificates it issues

Before discussing the renewal of a CA certificate, it's helpful to understand how the end of the validity period of a CA affects the validity period of the certificates it issues. Certificate Services enforces a rule that a CA never issues a certificate to be valid beyond the expiration date of its own certificate. Therefore, when a CA's certificate reaches the end of its validity period, all certificates it has issued will also expire. This way, if the CA is purposely not renewed and the CA reaches the end of its lifetime, a PKI administrator can be assured that all the certificates that the now-expired CA has issued can no longer be used as valid security credentials. In other words, there will be no "orphaned" certificates that are still within their validity period but which have been issued by a CA that is no longer valid.

To illustrate how a decreasing validity period works, consider the following scenario: An organization installs a root CA with a certificate validity period of five years. The organization then uses this root CA to issue certificates with a validity period of two years to subordinate CAs. For the first three years every certificate issued to a subordinate CA by the root CA will continue to have a validity period of two years. After three years, when there is less than two years left in the validity period of the root CA certificate, Certificate Services begins to reduce the validity period of the certificates issued by the root CA so that they do not exceed the end of the CA's certificate's expiration date. Therefore, after four years, the CA issues subordinate CA certificates that are valid for one year. After 4.5 years, issued subordinate CA certificates have a validity period of only six months.

Certificate Services allows for the following maximum validity periods that are based on the type of certificate. Except for the root CA, none of these validity periods are configurable by the CA administrator:

Type of certificate	Maximum validity period
Root CA	Specified during setup of Certificate Services
Subordinate CA, Internet Protocol Security, Enrollment Agent, Domain Controller	Two years
All other certificates	One year

Planning for the renewal of a CA

Since a CA that is approaching the end of its own validity period issues certificates valid for shorter and shorter periods of time, you need to have a plan in place to renew the CA well before it expires in order to avoid issuing certificates of a very short validity period.

One renewal consideration: When you renew a CA, you have the option of re-using its existing key pair or generating a new key pair. When you generate a new key pair for a CA that is being renewed, a new certificate revocation list (CRL) distribution point is also created. This is to ensure that the key used to sign a certificate issued by the CA also matches the key used to sign the CRL. For more information about how renewing a CA with a new key affects certificate revocation and the name of CRLs, see [Revoking certificates and publishing CRLs](#).

The following strategies are presented as possible approaches an organization could take when planning for CA renewal. You may need to adapt these to your specific situation.

Renewing a root certification authority

Since the root CA is the most critical CA in the hierarchy, you may prefer to have a strategy here that reduces the need to renew the root certificate often.

The first consideration is choosing the key length of the root's public key and private key pair during setup of the root authority. By using a long key length, which is generally more secure against brute force attack by a hacker than a shorter key length, you increase the length of time that the CA can use the same private key and have reasonable confidence that it has not been compromised. The second consideration is establishing the validity period of the root certificate itself. In general, you will want to create a root certificate that has a shorter validity period than the estimated lifetime of the key.

Keeping these considerations in mind, a possible strategy for setting up a root CA that reduces the need for frequent renewal would be to create a 4096-bit RSA key during Certificate Services setup. Given the state of computer technology in the late 1990's, one estimate is that a 4096-bit private key is reasonably secure from a brute force attack for 15-20 years. After creating the 4096-bit key in Certificate Services setup, you could create a root certificate using the 4096-bit key that is valid for five years. Afterwards, the CA's certificate should be renewed every four years (one year before the expiration of the validity period), each time with a certificate validity of five years. Of course, every time the CA certificate is renewed, the administrator will have to assess whether the same key, given current computer technology and other security considerations, can be used with confidence for the next five years.

Renewing a subordinate certification authority

Intermediate CAs

Within an organization's certification hierarchy, some subordinate CAs may be "intermediate" CAs--in other words, they don't issue certificates to end users or computers, they only issue certificates to other subordinate CAs below them in the certification hierarchy. For these intermediate CAs, given their limited role and the relative ease of monitoring their certificate database logs, a possible strategy may be to renew them a year to six months before they expire and re-use the existing key.

Issuing CAs

For subordinate CA's that do issue certificates to end users and computers, sometimes referred to "issuing" CAs, a preferable strategy may be to renew the CA's certificate regularly with a new key 6-12 months before the end of the CA's validity period. This makes an attack by a hacker on any one key less valuable, since any compromised key would have a relatively limited lifetime.

The other advantage of renewing an issuing CA using a new key is CRL management. When a CA is renewed with a new key, it begins to publish a separate CRL for the revoked certificates it has issued using the new key. It also will continue to publish a CRL for certificates signed with the old key, for as long as those revoked certificates validity period is still in effect. This is something a CA administrator may want to exploit if the CA is issuing a large number of certificates and, potentially, revoking a large number of those certificates. It may be advantageous to reduce the possibility of having one huge CRL that certificate verifiers have to download by instead issuing a number of certificates with one key, renewing the CA early into its validity period with a new key, then issuing a number of certificates using the new key. In this way, you will reduce the size of the CRL that certificate verifier has to download when presented with a certificate from an issuing CA.

For more detailed information about planning for renewal and renewing Windows 2000 certification authorities, refer to the Windows 2000 Resource Kits.

Procedures to renew CAs

See [Renew a root certification authority](#) for the procedure to renew a root CA.

See [Renew a subordinate certification authority](#) for the procedure to renew a subordinate or intermediate CA.